

1. Who can recover a private key within an enterprise CA implemented by Microsoft Certificate Services 2003?

A. Key Recovery Agent

B. CA Administrator

C. Backup Operator

D. Certificate Manager

2. Certificate Repository serves to:

A. Logging the events related to the certificates management

B. CRL distribution

C. Interface used by the end-users for submitting the issuing certificates requests

D. The distribution of digital certificates

3. What is the extension that defines the categories of applications that can use a digital certificate?

A. Key Usage

B. Subject Public Key Info

C. Extended Key Usage

D. Policy Constraints

4. What is the role of an HSM - Hardware Security Module?

A. Accelerates the cryptographic operations

B. Ensures the cryptographic keys protection

C. Allows keeping secret the used cryptographic algorithms

D. Ensures protection for the computer which runs the installed CA software

5. The term "key escrow" refers to:

- A. Protocol which negotiates a session key between two entities
- B. Prime number test used in the RSA key generation process
- C. Check if a user holds the private key associated to the public key from a digital certificate
- D. Arrangement by which the cryptographic keys are stored on a trusted third party and used when necessary**

6. How are the users' private keys stored in a database of an enterprise CA implemented by Microsoft Certificate Services 2003?

- A. without being encrypted, the protection being ensured by the access grants and credentials at the database level
- B. encrypted by the Key Recovery Agent's public key**
- C. encrypted with the Backup Operators private key
- D. encrypted with the CA's private key

7. The advantages of using a Bridge CA in order to ensure the PKI interoperability are:

- A. It is a standardized method and therefore supported by most PKI applications
- B. Reducing the number of bilateral cross-certification**
- C. All users will use a single point of trust - Bridge CA
- D. Simplifying the process of certification policy equivalency

8. What should be done to ensure the protection of the cryptographic keys?

- A. Keeping the secret of the encryption algorithms used
- B. The choice of key lengths as large as possible
- C. To use validated cryptographic algorithms and modules**
- D. The users awareness of the importance of correct cryptographic key management

9. When do you need to revoke a digital certificate?

A. If the cryptographic algorithms and key lengths are no longer suitable for the necessary protection

B. If the private key associated to the public key certificate is compromised

C. If the user leaves the organization

D. When the user's digital certificate came into possession of a third party

10. The main features of the OCSP protocol are:

A. It is used by the clients in order to access the Certificate Repository

B. Relieves the clients by the CRLs specific complex processing

C. Allows the clients to revoke the certificates in case of the compromise of the private key

D. It is a simple request / response protocol (?)

11. RA Registration Authority is designed to:

A. Check the issuing certificate requests and the identity of the final entities

B. Archive the private keys used to decrypt data by the end-users

C. Record the users private keys used to sign data

D. Verify that users are using the key pairs in a correct manner

12. What are the minimum recommended key lengths to use for the moment, in order to ensure data protection for 10 years?

A. 128 bits for symmetric algorithms and 2048 bits for public key algorithms (KEY MANAGEMENT EN slide 15)

B. 256 bits for symmetric algorithms and 4096 bits for public key algorithms

C. 192 bits for symmetric algorithms and 3072 bits for public key algorithms

D. 64 bits for symmetric algorithms and 1024 bits for public key algorithms

13. CA Certification Authority are designed to:

A. Establish the relationships with other CAs for cross-certification

B. issue and revoke digital certificates

C. archive the private keys used by the end-users for signing data

D. publish the digital certificates in the Repository

14. Which of the following statements about the Microsoft Certificate Services 2003 version Enterprise - are true?

A. Allows the implementation of the "m from n" schemes in order to restore the private keys

B. In addition to Active Directory, it can be integrated with any directory server

C. Use IIS Web Server as user interface

D. Allows the definition of new templates for certificates

15. How is possible to determine the level of trust in a digital certificate issued by a Certification Authority:

A. Based on Subject Key Identifier extension

B. By reading Trust Level attribute from the Repository

C. The analysis of CP and CPS

D. Using the OCSP protocol

16. Which of the following statements are true about the hierarchical PKI architectures?

A. There is a single point of trust - Root Certification Authority

B. The compromise of the private key does not affect the other authority

C. The certification paths are unidirectional and easy to determine

D. The certification paths are dependent by the user who does the validation

Obiective

- Înțelegerea **managementului cheilor criptografice**
 - Alegerea **algoritmilor și lungimii cheilor**
 - Cunoașterea **PKI** (Infrastructuri de Chei Publice)
 - Proiectarea și implementarea unui **PKI organizațional**
-

1. Managementul cheilor criptografice

Ciclul de viață al unei chei:

1. **Generare** – cu generatoare deterministe (pseudoaleatoare) sau nedeterministe (surse fizice).
 2. **Distribuție** – critică! Ex:
 - Simetric: curier, QKD
 - Asimetric: certificate digitale
 3. **Instalare** – pe disk (ex: PKCS #12) sau dispozitive (HSM, smart card)
 4. **Salvare / Restaurare** – doar chei de decriptare, nu și cele de semnătură!
 5. **Utilizare** – memorie sigură, UI securizat
 6. **Arhivare** – doar pentru audit, nu în producție!
 7. **Ștergere** – cu algoritmi de wipe (suprascriere aleatoare)
-

Algoritmi recomandați

✓ Funcții hash:

- **SHA-2**: 224, 256, 384, 512 biți
- **SHA-3 (Keccak)**

✓ Simetrice:

- **AES**: bloc 128 biți, cheie 128/256
- **3DES (TDEA)**: 64 biți, cheie 3×56

✓ Asimetrice:

- **Semnături**: RSA, DSA, ECDSA
- **Schimb de chei**: DH, RSA wrapping

Lungimea cheilor

- Forța brută crește **exponențial** cu lungimea cheii.
- Exemple: DES spart în 4.5 zile (1998), 250 miliarde chei/s (1999).
- Recomandări: keylength.com

✓ Best Practices

- Cheie = un singur scop (ex: doar criptare)
- Schimbare periodică a cheilor
- Stocare pe dispozitive sigure (HSM, smart card)
- Plan de acțiune în caz de compromitere
- Algoritmi validați (FIPS 140-2)



2. Infrastructura de Chei Publice (PKI)



Criptografie cu chei publice:

- Cheie publică ↔ cheie privată
- Probleme: distribuția sigură a cheilor publice
- Soluție: **PKI + Certificate digitale**



Certificate digitale (X.509 v3)



Structură:

- Versiune, Număr serial, Algoritm semnare (OID)
- Emitent (Issuer DN), Subiect (Subject DN)
- Cheie publică
- Extensii (ex: Key Usage, CRL Distribution Point, Authority Info Access)



Extensii standard:

- Authority Key Identifier
 - Key Usage / Extended Key Usage
 - Certificate Policies
 - Subject Alternative Name etc.
-



Tipuri de certificate

- **X.509** – standardizat
 - **PGP** – Web of Trust
 - **SPKI** – autorizare
 - **Certificate de atribut** – privilegii (PMI)
-



Componente PKI

- **CA (Certification Authority)** – semnează certificate
 - **RA (Registration Authority)** – verifică identitatea
 - **Repository** – depozit certificate
 - **End Entities** – utilizatorii finali
-



Arhitecturi PKI



Ierarhică:

- Root CA → Sub CA
- Avantaje: simplă, scurtă, scalabilă
- Dezavantaj: compromiterea root-ului = dezastru



Rețea:

- Cross-certificare între AC
 - Avantaje: flexibilitate, model natural
 - Dezavantaje: validare complicată, greu de optimizat
-

Politici și Practici de Certificare

- **CP (Certificate Policy)**: ce reguli trebuie respectate
 - **CPS (Certification Practice Statement)**: cum sunt aplicate aceste reguli
 - Standard: **RFC 2527**, **RFC 3647**, ETSI TS 101 456
-

Validarea stării certificatelor

CRL (Certificate Revocation List)

- Fișiere publicate periodic cu certificate revocate
- Problemă: frecvență de actualizare vs. consum rețea

Delta CRL

- Doar modificările față de CRL-ul de bază
- Precizie mai mare

OCSP (Online Certificate Status Protocol)

- Cerere/răspuns online
 - Răspunsuri: *good*, *revoked*, *unknown*
-

Interoperabilitate PKI

Soluții:

- Certificate Trust List (CTL) – ex: Windows
 - Cross-certificare – între AC-uri
 - **Bridge CA (BCA)** – facilitează echivalarea între PKI-uri
-

Implementare PKI organizațional

1. Analiză cerințe
2. Definire proiect
3. Proiectare arhitectură (topologie: root CA offline, sub CA-uri etc.)
4. Alegere produse (ex: Entrust, EJBCA, Microsoft, GlobalSign)
5. Pilot/testare
6. Implementare
7. Instruire personal
8. Interoperabilitate + legislație